# SERVICE-TO-SERVICE AUTHENTICATION MIT KEYCLOAK UND SPRING SECURITY

JavaLand 2026

breuninger

breuninger
breuninger

## about:blank

T-Shirt

**89,99 €**

inkl. MwSt., kostenloser Standardversand und Rückversand

Farbe: **WEISS / SCHWARZ**

Größe

Dieser Artikel fällt **normal aus.**

Bitte Größe wählen →

Sofort lieferbar

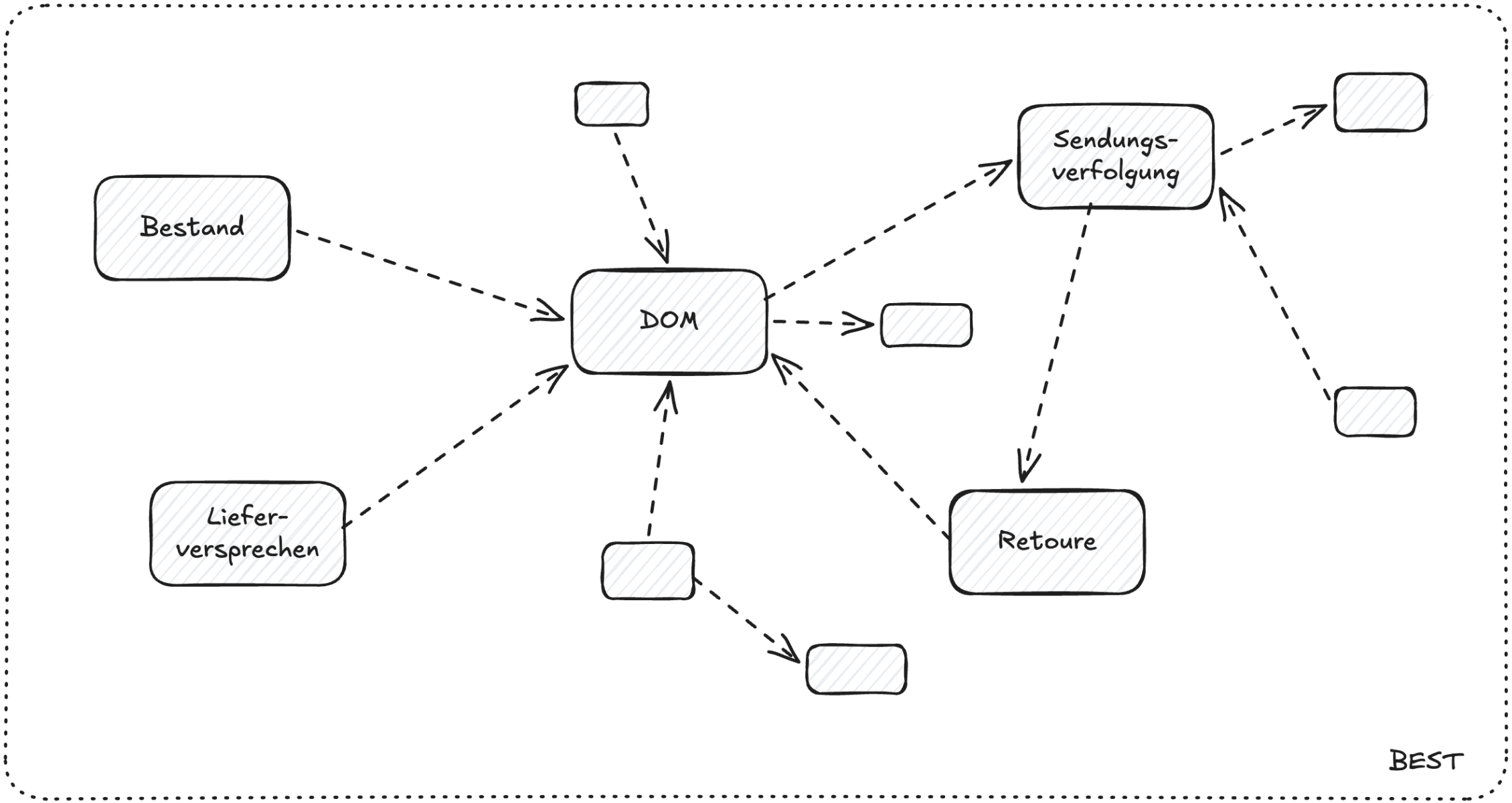
IN DEN WARENKORB

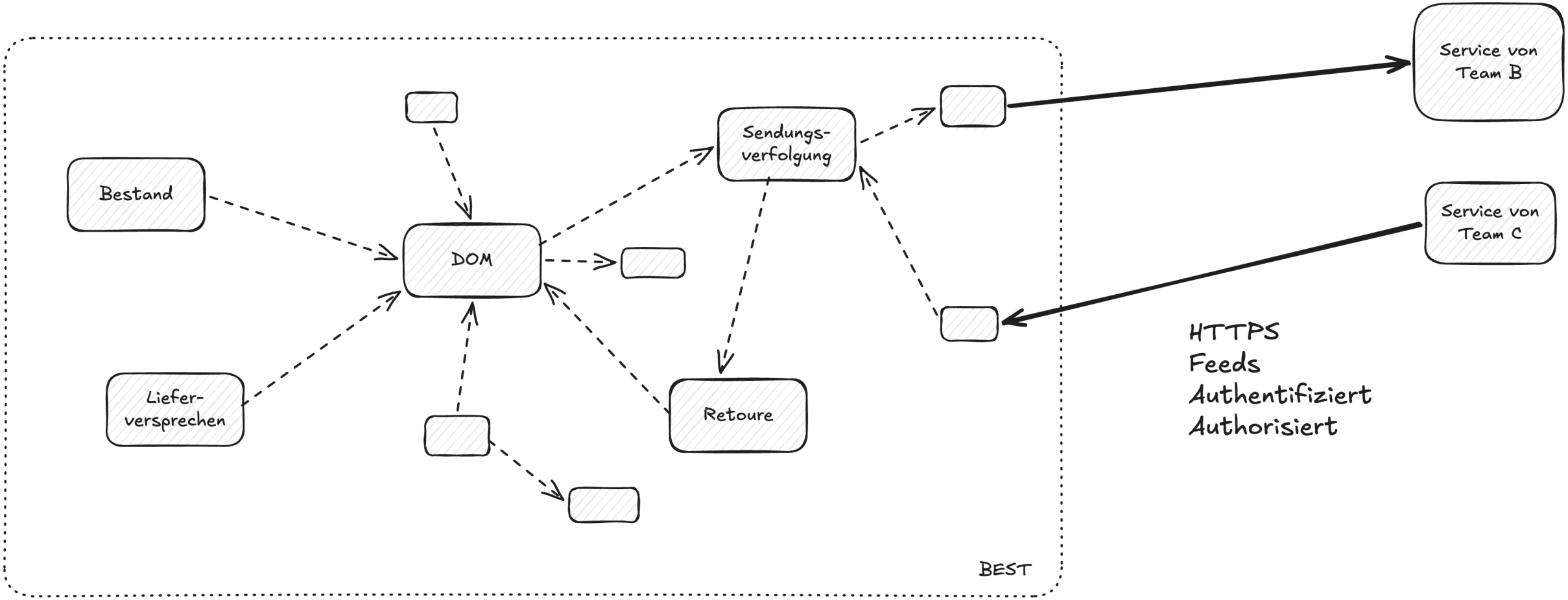
Jetzt in Ihrem Haus reservieren

**Entspannt zu Hause entscheiden**

Sollte das neue Lieblingsstück doch nicht gefallen, können Sie es kostenfrei innerhalb von 30 Tagen zurücksenden.

Zu Beschreibung, Passform und Material


Bestand
DOM
Sendungs-
verfolgung
Liefer-
versprechen
Retoure
BEST


Bestand
DOM
Sendungs-
verfolgung
Liefer-
versprechen
Retoure
BEST
Service von
Team B
Service von
Team C
HTTPS
Feeds
Authentifiziert
Authorisiert

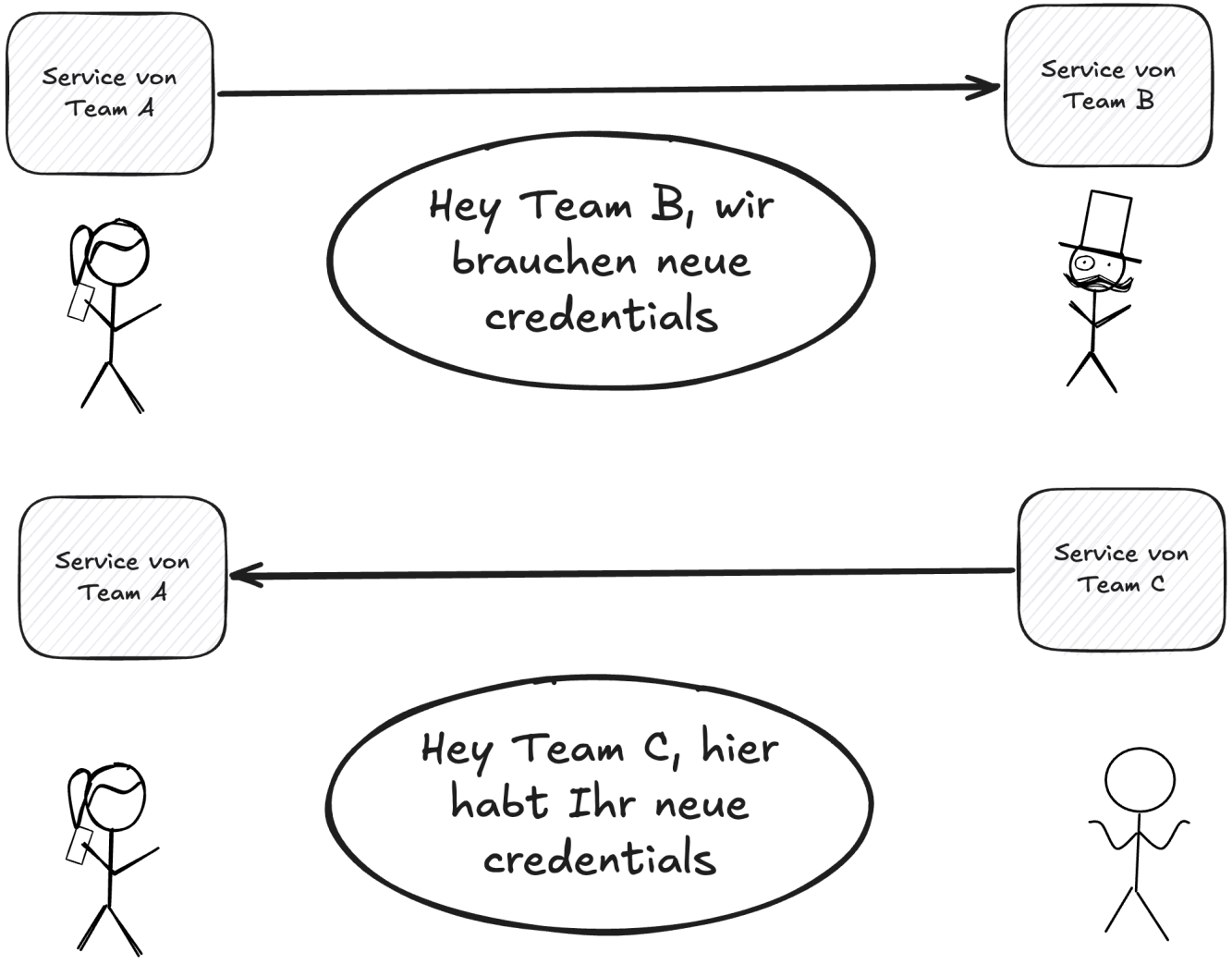
# Basic Auth

```
GET https://team-b.de/orders
Authorization: Basic dXNlci1iOjEyMw==
```

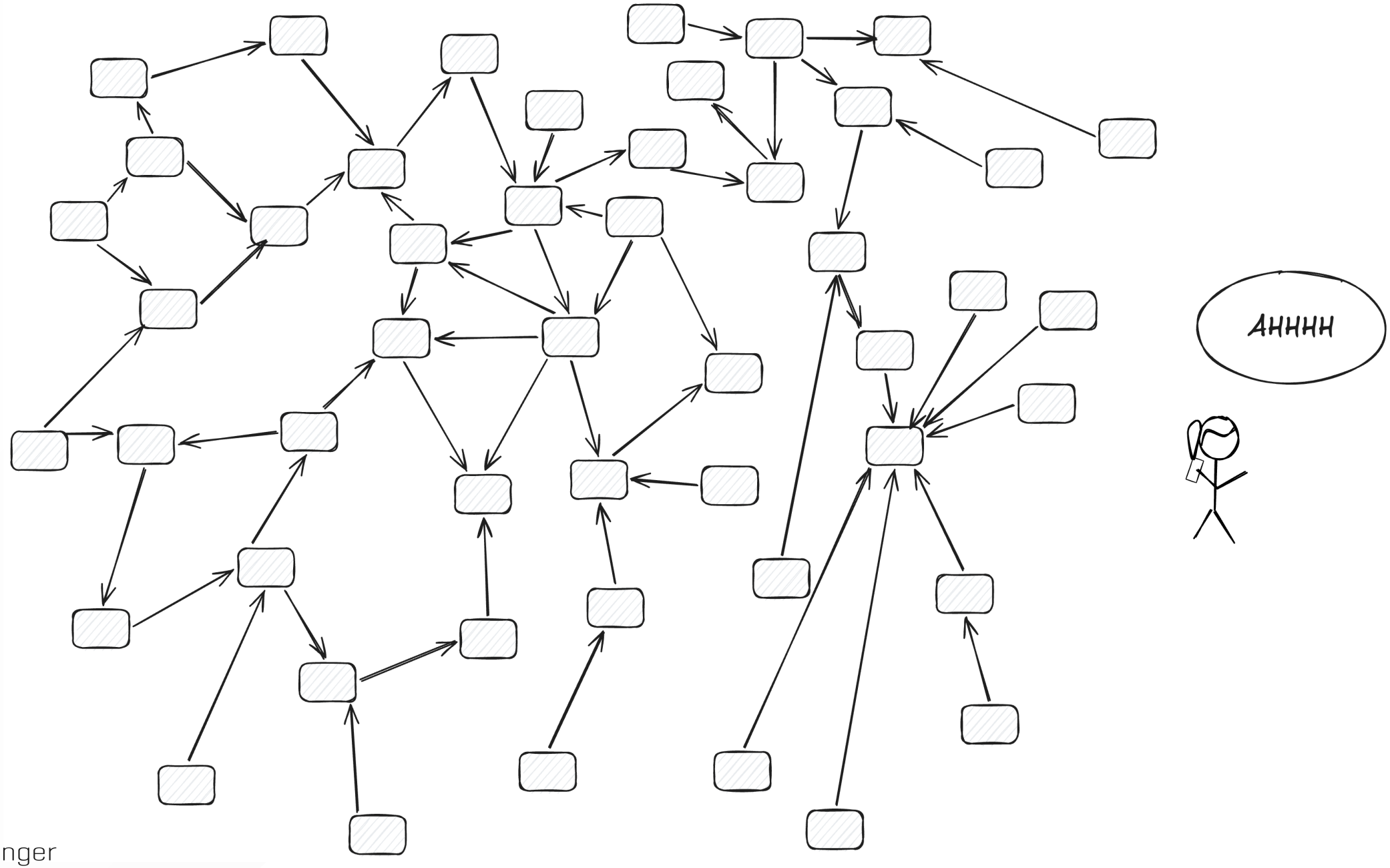
```
GET https://team-a.de/returns
Authorization: Basic dGVhbS1hOjQ1Ng==
```

# WAS PASSIERT, WENN JEMAND DAS UNTERNEHMEN VERLÄSST?

# Rotieren - Basic Auth




breuninger




breuninger

# OAUTH 2

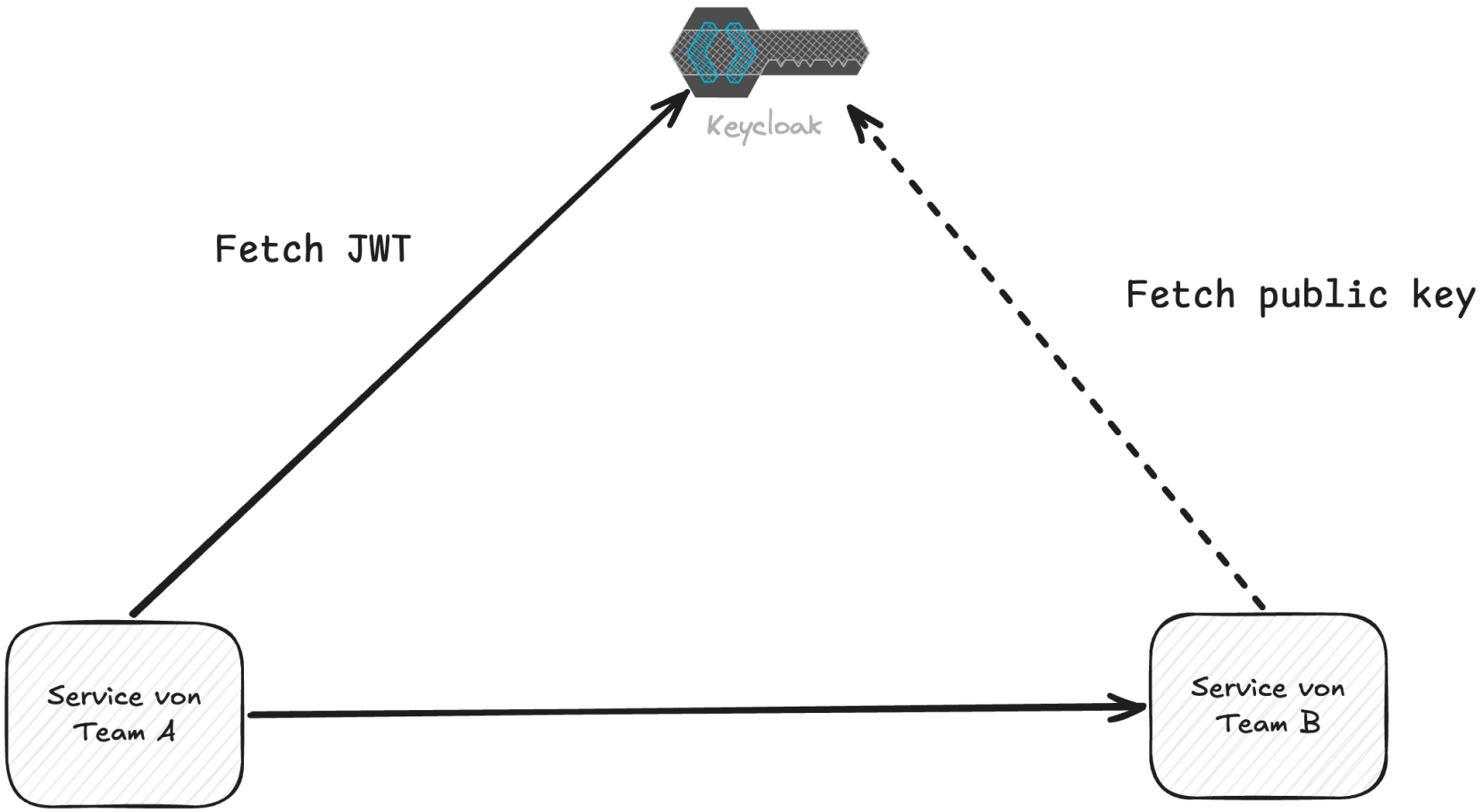
# Basic Auth vs OAuth2 Client Credentials

| | Basic Auth | OAuth2 Client Credentials |
|---|---|---|
| **Identität** | Statischer Username | Access Tokens (JWT) |
| **Secret Ownership** | Server & Client kennen Secret | Client und OAuth2-Provider kennen Secret |
| **Gültigkeit** | Unbegrenzt | Kurzlebige JWTs |
| **Granularität** | Oft Vollzugriff | Feingranular über Scopes |
| **Offboarding** | Credentials in Server & Client rotieren | Client-Credentials rotieren |
| **Rotation** | Individueller Prozess | Einfach Automatisierbar |
| **Kopplung** | Hoch zwischen Teams | Entkoppelt durch Keycloak |

# Authorization Code Flow vs Client Credentials Flow

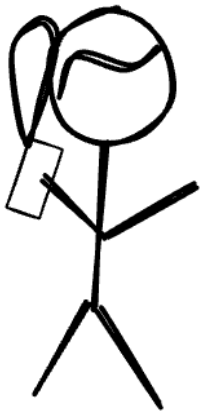
| | Authorization Code Flow | Client Credentials Flow |
|---|---|---|
| **Akteur** | Mensch mit Browser | System (M2M) |
| **Identität** | User-Identität | Service-Identität |
| **Interaktion** | Login-Maske, Redirect | API-Call |
| **Token-Inhalt** | User-Details & Permissions | Service-Scopes & Rollen |
| **Grant Type** | authorization_code | client_credentials |
| **Use Case** | Mitarbeiter-Login | Service A ruft Service B auf |

# OAuth2 client credential flow




```
GET https://team-b.de/orders
Authorization: Bearer ey...
```

# Rotieren - OAuth2



terraform apply

# CODE

# Zusammenfassung

- Keycloak: Secret-Rotation z.B. mit terraform
- Server: oauth2ResourceServer mit Scope-Validierung
- Client: requestInterceptor mit OAuth2AuthorizedClientManager
- Optional: Secret dynamisch in AccessTokenResponseClient setzen

Photo by Maick Maciel on Unsplash

# VIELEN DANK

https://github.com/nikolashermann/javaland2026

niko@breuninger.de
@nikolashermann